AWD Check List

0. 记录平台帐号密码

一般会拿到平台URL与登录帐号密码、靶机IP与SSH帐号密码，万一没有就爆破弱口令。

1. 更改SSH默认密码

```
passwd ubuntu
>当前密码
>更改密码
>确认密码
```

2. 备份题目源码

> /var/www/html/
> /var/www/
> /var/lib/tomcat9/webapps/ROOT /
> /home/ubuntu/
> /root/
> /

```
find / -name '*.php'
tar -zcvf web.tar.gz /var/www/html/
zip web.zip -r /var/www/html/
7za a -t7z web.7z -r /var/www/html/
scp -r ubuntu@172.16.100.1:/var/www/html/ ./
```

- pwn题直接拷贝，包括run.sh

3. 备份数据库并更改密码

```
mysqldump --all-databases > back.sql
mysqldump -u root -p root databasename > back.sql
mysql -u root -p root databasename < back.sql
source back.sql
```

- 万一密码不对，从Web题database、config等文件中去找
- 备份完的sql文件要拷回来

```
# 监听地址
```

```
# /etc/mysql/my.cnf
# /etc/mysql/conf.d/mysql.cnf
bind-address=127.0.0.1
service mysql restart 或 systemctl restart mysql.service
# 数据库密码
use mysql;
set password for root@'%' = password('kbqn2020');
或 update user set password = password('kbqn2020') where user = 'root';
```

- 注意同步修改CMS配置

4. 更改Web后台密码

从数据库中找到并更改（可能不是明文，要分析哈希），或是通过管理后台功能修改密码

```
UPDATE admin SET passwd = 'kbqn2020' WHERE 'username' = 'admin'
```

5. Pwn通防

```
pwn_sandbox ./pwnbin
```

- 注意检查run.sh服务可用性

6. 检查开放端口

```
netstat -pantu 或 ss -pantu 或 lsof -i
ifconfig 或 ip addr
cat /proc/net/xxx
查看对应服务检查是否遗漏
```

7. D盾、Seay、漏洞库、IDA

```
a. d盾检查预留后门
b. seay检查危险函数
c. 漏洞库与文章
d. IDA...
删除服务器相应代码，不要删除页面（用于流量分析）
同时对备份文件进行Patch
```

8. 流量、文件、进程监控

```
mongod --dbpath /var/lib/mongo/ --logpath /var/log/mongodb/mongod.log --fork
./aoiawd.phar [-t kbqn2020]
```

```
./guardian.phar -i /home/ubuntu/pwn -s 回连IP:8023      # Pwn流量记录
./tapeworm.phar -s 回连IP:8023 -d /var/www/             # WebWAF(daemon)
./roundworm -d -s 回连IP -p 8023 -w "/var/www/;/home/" # 进程文件
```

- 要注意别被checkdown，挂了的话就改松通防规则

9. 批量攻击

SSH批量改密，MySQL批量改密，CMS文件读取，GetShell与权限维持

附：常用命令

杀不死马

```
ps aux | grep www-data | awk '{print $2}' | xargs kill -9
或 pkill -9 apache
```

更改权限

```
chmod -R 644 (-rw-r--r--)
chmod -R 700 (-rwx------)
chmod -R 755 (-rwxr-xr-x)
chown -R ubuntu
chgrp -R ubuntu
```

循环执行

```
while true;do id;sleep 3;done
```

计划任务

```
crontab -l
crontab -e
3 * * * * /bin/bash /home/ubuntu/do.sh
```

BusyBox、SFTP、kernel exp等

可能有部分提权效果

提权拿了高权限

防火墙（慎用）：参考iptables或firewall用法

```
# 锁属性
chattr -R +i /var/www/html
```

赛前准备与参考链接

漏洞库（先知、零组、searchsploit等）
安全工具（burpsuitepro、nmap、goby、msf、godzilla、D盾、Seay源代码审计等）
运维软件（mobaxterm、飞秋、nc、curl、python、navicat、wireshark、科来等）

- 系统时间与互联网同步
- 队内文件服务器与信息交流

出问题几乎是必然的，冷静思考解决方法就行，用当最后一名的心态放开打

https://www.freebuf.com/articles/network/201222.html
https://www.anquanke.com/post/id/84675
https://www.freebuf.com/articles/web/118149.html
https://www.anquanke.com/post/id/86984
https://www.hackblog.cn/?p=128
https://blog.csdn.net/like98k/article/details/80261603
https://blog.csdn.net/qq_42114918/article/details/82785960
https://www.jianshu.com/p/d21b7e1bffaf
https://blog.csdn.net/fallfeather/article/details/82828190
https://www.jianshu.com/p/25535f0b98d4
https://www.t00ls.net/articles-42278.html